

تقرير الاختبار الأمني للمنصة

منصة "سهم / ماتريكس برو" — Marketplace بإدارة مزودين وطلبات ونقاط واشتراكات مميزة
نطاق الاختبار: تطبيق الويب كاملاً (واجهة عامة + لوحة المزودين + لوحة الإدارة + واجهة API)

تاريخ الاختبار: 7 أغسطس 2026 | البنية: Node.js + Express + SQLite (معمارية معيارية /src) | حالة السيرفر: يعمل بلا أخطاء

ملخص تنفيذي

SQL Injection: آمن ✓	XSS: آمن ✓	CSRF: آمن ✓	Path Traversal: آمن ✓
File Upload: آمن ✓	Authentication: آمن ✓	Authorization: آمن ✓	الجلسات: آمنة ✓
Rate Limiting: مفعل ✓	HTTPS: مفعل ✓	كلمات المرور: آمنة ✓	الأسرار: محمية ✓

تم اختبار 12 محوراً أمنياً إجمالاً منها جميعاً ناجحة. لا توجد ثغرات حرجة مفتوحة (Critical/High). التوصيات الواردة في نهاية التقرير اختيارية.

1. حقن (SQL Injection) SQL

الاختبار / الإجراء	النتيجة
مراجعة كل الاستعلامات — جميعها عبر prepare () بوسائط معاملة (?)	آمن
-- Payload: ' OR 1=1	مرفوض (403)
--;Payload: 1); DROP TABLE vendors	مرفوض (403)
استعلامات ديناميكية (بحث، سجل نشاط، IN clause) تُبنى بوسائط فقط	آمن

2. البرمجة عبر المواقع (XSS)

الاختبار / الإجراء	النتيجة
ترميز كل مخرجات بيانات المستخدم (esc()/jsStr()/safeUrl) في الصفحات الثلاث	مطبق
تعقيم الروابط (http/https فقط) في السمات href/onclick/src	مطبق
رؤوس الحماية: Content-Security-Policy (object-src 'none', base-uri 'self', frame-ancestors 'none')	مفعّل
X-Content-Type-Options: nosniff + X-Frame-Options: DENY	مفعّل

3. تزوير الطلبات عبر المواقع (CSRF)

الاختبار / الإجراء	النتيجة
POST /api/orders بدون توكن الصفحة	403
POST /api/support مع توكن الصفحة الصحيح	200
تغطية: orders / ratings / complaints / support / views	مكتملة
حقن توكن unique لكل صفحة HTML عبر meta csrf-token وإرساله بالرأس x-csrf-token	مطبق

4. اجتياز المسارات (Path Traversal)

الاختبار / الإجراء	النتيجة
الوصول عبر 2Fserver.js%../	404
حظر مقاطع (..) + فحص بقاء المسار داخل جذر المشروع	مطبق
منع تحميل ملفات الأسرار (env / vault.enc / *.pem / *.db.)	404

5. رفع الملفات (File Upload)

الاختبار / الإجراء	النتيجة
رفع ملف نصي خبيث باسم png بنوع image/png	مرفوض (400)

مطبق	التحقق من الملفات أساساً (magic bytes) قبل الحفظ + الامتداد + النوع + حد 5MB
مطبق	أسماء ملفات عشوائية من الخادم (لا تُؤخذ من المستخدم)
200	رفع صورة حقيقية

6. المصادقة (Authentication)

الاختبار / الإجراء	النتيجة
دخول المشرف (Suhaib) بنجاح وقيمة is_admin=1	200
منع تسريب زمن الاستجابة (مقارنة تجزئة وهمية عند وجود مستخدم)	مطبق
تخزين bcrypt (10 جولات) + حد أدنى 8 أحرف	مطبق
رسالة خطأ معممة (لا تكشف وجود المستخدم)	مطبق

7. التفويض (Authorization)

الاختبار / الإجراء	النتيجة
api/vendor/profile/ بدون توكن	401
api/admin/stats/ بدون توكن	401
api/admin/stats/ بتوكن صالح	200
توكن رقمي / غير سداسي (IDOR): /4/	401
تحقق is_admin داخل الجلسة	مطبق

8. إدارة الجلسات

الاختبار / الإجراء	النتيجة
انتهاء صلاحية التوكنات (30 يوم) مع تنظيم تلقائي كل ساعة	مفعّل
توكن غير موجود / منتهي	401

إلغاء فوري عند تسجيل الخروج (logout)	مفعّل
--------------------------------------	-------

9. الحد من الطلبات (Rate Limiting)

الاختبار / الإجراء	النتيجة
محاولات دخول خاطئة متتالية	429 (مفحّ) "محاولات كثيرة"
حدود: دخول 10/15 د · واجهة عامة 200/د · كتابة عامة 40/10 د · إعداد 20/ساعة	مفعّلة

10. إعدادات HTTPS

الاختبار / الإجراء	النتيجة
HTTPS يعمل على المنفذ 3443 بشهادة ذاتية	مفعّل
HSTS عند الاتصال الآمن	مفعّل
توجيهه إجباري قابل للتفعيل عبر FORCE_HTTPS=1	جاهز

11. حماية كلمات المرور

الاختبار / الإجراء	النتيجة
bcrypt (10 جولات) ولا تُعرض كلمات المرور في استجابات API	مطبق
حد أدنى 8 أحرف في التسجيل	مفعّل

12. إدارة الأسرار (env. و vault)

الاختبار / الإجراء	النتيجة
env. و vault.enc غير قابلين للتحميل من المتصفح	404
تغطية gitignore. للملفات الحساسة (env, vault.enc, uploads/*, ./, /*.db, ssl)	مكتملة
كلمة سر vault عبر متغير بيئة فقط	مطبق

منخفض الأولوية:

- تفعيل `FORCE_HTTPS=1` في بيئة الإنتاج النهائية لفرض الاتصال الآمن وحماية بيانات الدخول.
- فرض سياسة كلمة مرور +8 أحرف على الحسابات القديمة عند أول تغيير لكلمة المرور.
- إضافة رأس `Cross-Origin-Opener-Policy: same-origin` لدعم إضافي ضد هجمات `break-out`.
- جدولة مراجعة دورية لتحديثات المكتبات (`npm audit`) كل ربع.

أُعد التقرير على نظام التقييم الأمني للمنصة: فحص آلي + تحقق يدوي لكل محور. — توقيع: أدوات الاختبار الآمن (deepseek- / opencode v4)